# OpenHarmony-Audit-Agent 工具使用说明书

对应题目一交付件 3。主体为审计工作流，CodeQL-AI 按需辅助验证。本说明书覆盖当前可执行入口、环境依赖、输入输出和原型 DEMO 操作。

## 1. 当前功能

主体可以加载配置、拆分分析单元、生成 worker 任务包、角色提示词与检查点提示词；配置模型和真实源码后，runner 可启动 Claude Code 会话，保存日志并按状态继续。角色负责源码调查和候选复核。真实 OpenHarmony 效果数据与漏洞材料后续补充。

CodeQL-AI provider 和 MCP 工具可独立调用，主任务包包含可选调用策略。自动工具调用、证据转换和完整入库链路仍需联调。HTML 模拟任务交接与方法原理，不连接实际 Agent 或扫描引擎。

## 2. 环境依赖

| 场景 | 依赖 | 配置说明 |
| --- | --- | --- |
| 离线 HTML | 现代浏览器 | 可直接打开 demo.html；无需模型、Python 或 Node |
| 本地网页服务 | Python 3.10+ | 标准库服务，仅监听 127.0.0.1 |
| 主体准备与状态读取 | Python 3.10+、pip、setuptools ≥ 68 | 基础 Python 包无第三方运行依赖；推荐独立虚拟环境 |
| 主体实际审计 | Claude Code、可用模型、认证、真实源码 | 配置 workflow 中 command/model 与环境变量；run 会调用模型 |
| 可选 CodeQL | CodeQL CLI、数据库、查询包、目标构建环境 | 源码审计无需 CodeQL；使用辅助静态分析时配置 |
| 可选 CodeQL-AI | .[codeql-ai]：FastMCP、angr、pyelftools、tabulate | 二进制需适合调试分析；Linux / WSL2 环境需单独验证兼容性 |
| 报告生成 | .[pdf]：ReportLab、pypdf、pdfplumber | 当前默认中文字体为 Windows msyh.ttc；其他系统需指定可用字体 |
| 性能采样 | .[benchmark]：psutil | 采样进程树 RSS，远端模型服务内存不在本机统计范围内 |
| 浏览器回归 | Node.js 22+（建议）、npm、Chrome | npm ci 安装 puppeteer-core；不下载 Chrome |

OpenAI-compatible 适配器可单独调用，支持 base_url、模型名和 API key 环境变量；当前主体并行 runner 仍使用 Claude Code。配置示例含占位值，必须替换。密钥通过环境变量提供，不写入配置或命令行参数。

## 3. 安装

在解压后的源码根目录执行以下 Windows PowerShell 命令。Linux / macOS 将解释器路径替换为 .venv/bin/python。安装可能需要访问包源，基础准备步骤在安装后可离线运行。

```
python --version
python -m venv .venv
.\.venv\Scripts\python.exe -m pip install -e .
.\.venv\Scripts\python.exe -m openharmony_audit --help
```

源码包包含主体提示词与配置。主体建议从源码目录以 editable 方式安装。运行实际任务前核对源码路径与版本，且使用新的运行目录。

## 4. 主体工作流操作

以下抽象目标仅验证结构，不读取真实 OpenHarmony 源码，也不调用模型。

```
.\.venv\Scripts\python.exe -m openharmony_audit workflow validate --workflow config/workflow.audit.example.json --target config/target.openharmony.abstract.json
.\.venv\Scripts\python.exe -m openharmony_audit workflow plan --workflow config/workflow.audit.example.json --target config/target.openharmony.abstract.json
.\.venv\Scripts\python.exe -m openharmony_audit workflow prepare --workflow config/workflow.audit.example.json --target config/target.openharmony.abstract.json --run-root reports/run-data --allow-missing-source
.\.venv\Scripts\python.exe -m openharmony_audit workflow status --run-root reports/run-data
```

validate 成功输出 VALID。plan 展示源码单元与 worker 分配。prepare 写入以下产物：

• plan.json：目标、运行时、阶段、分析单元与 worker 计划。

• workers/worker-*/assignment.json：该 worker 的范围与产物路径。

• prompt.md、roles.md、blind-verifier.md、checkpoint-prompt.md：总控与角色协议；总控提示词含可选辅助策略。

• shared/candidates、shared/verification、shared/reports：候选、复核与报告目录。

status 在未运行时显示 NOT_STARTED。prepare 只准备任务；重复使用目录会覆盖计划或提示词，不应用于覆盖正在运行的任务。

实际审计时复制配置为自己的任务配置，替换 source.root、revision、units 和 model。执行严格验证，并在 prepare 时去掉 --allow-missing-source。确认 Claude Code 与所用模型服务可用后执行：

```
.\.venv\Scripts\python.exe -m openharmony_audit workflow run --run-root reports/run-data
.\.venv\Scripts\python.exe -m openharmony_audit workflow status --run-root reports/run-data
```

run 启动真实 Agent，会消耗模型配额。输入中的源码路径对 worker 必须可见。日志保存在 controller-*.stream.jsonl 与 checkpoint-*.stream.jsonl；Agent 按协议维护 worker-state.json 和 checkpoint.json。已有终态会跳过。使用 Ctrl+C 停止后检查产物完整性，再决定续作。当前工程未进行真实大规模审计或设备验证。

## 5. 辅助能力与其他命令

CodeQL-AI 仅在候选问题适合、依赖可用时调用。MCP 服务入口位于 src/openharmony_audit/engines/codeql_ai/mcp/server.py；具体工具参数保留在该模块及 provider 中。只生成任务包不等于配置了 MCP；需在 Agent 环境中单独配置服务。

```
.\.venv\Scripts\python.exe -m pip install -e ".[codeql-ai]"
.\.venv\Scripts\python.exe -m openharmony_audit normalize-sarif --sarif path/to/results.sarif --output reports/findings.json
.\.venv\Scripts\python.exe -m pip install -e ".[pdf]"
.\.venv\Scripts\python.exe -m openharmony_audit report --output reports/technical-report.md --pdf reports/technical-report.pdf
```

SARIF 路径需要替换为实际文件。report 当前生成技术说明书，不从 findings.json 自动生成完整漏洞报告。旧 prepare 和 validate-target 为基础计划兼容入口；主体任务应使用 workflow 子命令。

## 6. HTML 与视频操作

双击 frontend/demo.html，或运行 python scripts/serve_demo.py 后访问 http://127.0.0.1:8765/demo.html。端口占用时添加 --port 8766。Ctrl+C 结束服务。

演示共八章：主体定位、任务与交接、角色审计案例、按需路径验证、独立复核、经验回写、评估设计、总结。第二章可模拟证据返回、保存检查点和恢复；状态仅保存在本页内存。第三章包含五个子步骤；第四章拖动长度与切换保护条件，展示有限整数模型。第五、六章点击结论与经验环节。

方向键与 PageUp / PageDown 翻页；N 打开讲解提示，F 全屏，Escape 关闭提示并暂停自动播放。输入控件保留原生键盘行为。原工作台保留在 index.html。

frontend/narration.html 是对应的逐页口语稿，操作提示不用朗读。交付目录提供带字幕的原型操作视频；视频展示真实页面操作及任务准备结果，未运行真实扫描、符号执行或 PoC。可根据讲稿另外录制本人配音版本。

## 7. 常见问题

| 现象 | 检查方式 |
| --- | --- |
| No module named openharmony_audit | 确认在根目录安装，安装和运行使用同一虚拟环境 |
| source root does not exist | 实际任务检查路径；抽象 prepare 使用 --allow-missing-source |
| missing prompt template | 保留源码包 prompts 目录；检查 workflow.promptDir |
| 模型启动失败 | 检查 claude 命令、model、认证环境变量和网络；准备步骤无需模型 |
| 没有 CodeQL 数据库 | 主体源码审计仍可推进；需要数据库的辅助检查标记为不可用 |
| PDF 字体不存在 | 当前 CLI 默认 Windows 字体；build_pdf 支持 font_path 参数 |
| 页面与后台结果不同 | HTML 是抽象方法演示，不连接后台；真实结果以运行产物为准 |

## 8. 工程检查与性能复测

```
python -m unittest discover -s tests -v
python -m pip install -e ".[benchmark]"
python scripts/measure_command.py --output reports/perf-run.json --scope source-audit --snapshot YOUR_COMMIT -- .
\.venv\Scripts\python.exe -m openharmony_audit workflow run --run-root reports/run-data
```

测试需在已安装基础包的环境执行。性能命令用于实际审计，会运行其后的真实命令；测量前替换快照并准备完整任务。输出含墙钟时间、采样进程树 RSS、环境与退出码。命令输出保存在同名 stdout.log；提交前检查其中是否有敏感材料。各阶段口径和当前数据见性能说明。

浏览器检查在 frontend 目录运行 npm ci、npm run test:demo。旧工作台检查 npm test 需要启动本地网页服务。工程检查不能代替漏洞效果评测。